ETH
Eidgenössische Technische Hochschule Zürich
Swiss Federal Institute of Technology Zurich

Master's Thesis Proposal

Data Protection Formal Reasoning

Supervisor: Dr. Srđan Krstić, Hoang Nguyen
Professor: Prof. David Basin

1 Prerequisites

Some familiarity with the following topics:

- Access control.
- The General Data Protection Regulation (GDPR) [10].
- Model-driven development for enforcing data protection [11] and its specification language (namely, the Object Constraint Language [12]).
- First-order logic and the use of Satisfiability Modulo Theories [2] solvers (e.g., cvc5 [1]).

2 Motivation

Enforcing security (e.g., fine-grained access control [14]) and privacy (e.g., purpose-limitation [10]) policies in today's data-centric applications is both critical and challenging. It is critical because of the high economic and social consequences of enforcement failure. It is challenging as these policies are not yet well-supported by current technologies: they are typically implemented in an ad-hoc manner, which makes system maintenance and evolution error-prone and time-consuming. As a result, broken access control is the most common web application vulnerability according to the most recent OWASP Top 10 report [13], whereas data-protection violation fines have reached an all-time high [5].

Basin et al. [4] propose a *model-driven security* (MDS) approach for building systems in which security policies, expressed as fine-grained access control permissions, are formalized as OCL authorization constraints within a security model alongside the application's data model. `ActionGUI` [3] implements this methodology and generates fully functional, secure data-centric web applications. More recently, Krstić et al. [11] propose *model-driven privacy* (MDP), which extends MDS with a new privacy model capturing *purpose-limitation* and *consent*, and introduce ν`ActionGUI`, a new tool that supports both fine-grained access control and the aforementioned privacy requirements.

In both approaches, security and privacy models are defined formally using modeling languages. Using model transformations, correct-by-design enforcement code is generated from these models. It is therefore critical to design these models *correctly*, as logical errors, over- or under-specification in these models directly lead to flawed generated enforcement. García de Dios et al. [8] showed how formal reasoning about FGAC policies in `ActionGUI` [3] can be carried out by (i) mapping OCL authorization constraints and data-model invariants to first-order logic using the `OCL2FOL+` mapping [6], and then (ii) using the Z3 SMT solver [9] to answer security queries, e.g., "Is there any scenario in which a Worker can read another employee's salary?".

However, that work can be extended in two significant dimensions.

- First, it targets ActionGUI's security model, which does not cover the security extensions introduced in the new νActionGUI tool.
- Second, it does not address the privacy concerns. To the best of our knowledge, there is no existing methodology for formally reasoning about purpose-limitation and consent queries.

A more expressive OCL-to-FOL mapping, OCL2MSFOL [7], was later proposed by Dania and Clavel. It maps OCL to *many-sorted* first-order logic (MSFOL) and significantly improves coverage: it handles UML generalization, generalization-related OCL operators, and generates satisfiability problems that can be handled efficiently by SMT solvers with finite-model-finding capabilities (e.g., cvc4). This improved mapping may also provide better reasoning capabilities.

3 Objective

The objective of this thesis is to establish a formal reasoning methodology for the combined security and privacy models of νActionGUI, analogous to what SecProver [8] provides for ActionGUI, but extended in the following dimensions:

1. **Extended security model.** νActionGUI introduces method execution permissions (i.e., execute/execute*) and manipulation actions on entities' properties (i.e., init/write). We will extend the mapping from OCL to FOL and the set of formal reasoning questions to cover these new extensions.
2. **Privacy model.** We will develop a first-order logic translation of the νActionGUI privacy model, which consists of privacy notions such as personal data, purposes, and consent. We will investigate how formal reasoning can be applied to queries about privacy policy compliance, taking into account the interaction between privacy requirements and security permissions.
3. **Tool support and evaluation.** We will implement an extended reasoning tool and evaluate it on a set of non-trivial models from some of the νActionGUI case studies.

4 Tasks

We divide the thesis tasks into four main work packages (WPs).

(WP1): Background study and review

1. Study ActionGUI's security model and their reasoning tool SecProver.
2. Study νActionGUI's extended security model and the new privacy model [11].
3. Review different OCL to FOL mappings (e.g., to MSFOL [7]) and their associated tools.
4. Review the state-of-the-art SMT solvers and their capabilities.

(WP2): Extending OCL and security-model reasoning for νActionGUI

1. Extend the translation from OCL to FOL to cover the OCL syntax supported in the νActionGUI and, if applicable, with a more expressive OCL to FOL mapping definition.
2. (if applicable) Extend the translation from OCL to FOL to take advantage of the state-of-the-art SMT solvers.
3. Extend the first-order logic translation of the security model to support νActionGUI's extended action hierarchy:
    - Method execution permissions and the execute/ execute* actions.
    - The init and write property actions and their interaction with create permissions.

(WP3): Formal reasoning for the privacy model

1. Develop an FOL translation of the νActionGUI privacy model.

2. Identify queries specific to the privacy model and conduct a translation to formally reason about these queries.

(WP4): Tool implementation and evaluation

1. Implement the reasoning tool that accepts ν`ActionGUI` security and privacy models as input and generates the corresponding FOL theory files.
2. Conduct case studies using the ν`ActionGUI` examples to showcase the translation soundness and applicability.
3. Compare the expressiveness and coverage of the tool with that of the original `SecProver`.
4. (Optional) Integrate the formal reasoning technique into the ν`ActionGUI` tool.

5 Deliverables

The following deliverables are due at the end of the project:

Final report The final report should consist of an introduction, a theoretical background section, sections describing the work packages and their outcome, and a conclusion. The report must be written in English.

Source code Complete development, including easily reproducible evaluation.

Presentation At the end of the thesis, a 20 minute presentation must be given in an Information Security group seminar. It should give an overview and discuss the most important highlights of the work.

References

[1] Haniel Barbosa, Clark W. Barrett, Martin Brain, Gereon Kremer, Hanna Lachnitt, Makai Mann, Abdalrhman Mohamed, Mudathir Mohamed, Aina Niemetz, Andres Nötzli, Alex Ozdemir, Mathias Preiner, Andrew Reynolds, Ying Sheng, Cesare Tinelli, and Yoni Zohar. cvc5: A versatile and industrial-strength SMT solver. In Dana Fisman and Grigore Rosu, editors, *Tools and Algorithms for the Construction and Analysis of Systems - 28th International Conference, TACAS 2022, Held as Part of the European Joint Conferences on Theory and Practice of Software, ETAPS 2022, Munich, Germany, April 2-7, 2022, Proceedings, Part I*, volume 13243 of *Lecture Notes in Computer Science*, pages 415–442. Springer, 2022.

[2] Clark W. Barrett, Roberto Sebastiani, Sanjit A. Seshia, and Cesare Tinelli. Satisfiability modulo theories. In Armin Biere, Marijn Heule, Hans van Maaren, and Toby Walsh, editors, *Handbook of Satisfiability*, Frontiers in Artificial Intelligence and Applications, pages 825–885. IOS Press, 2009.

[3] David Basin, Manuel Clavel, Marina Egea, Miguel Angel García de Dios, and Carolina Dania. A Model-Driven Methodology for Developing Secure Data-Management Applications. *IEEE Trans. Software Eng.*, 40(4):324–337, 2014.

[4] David Basin, Jürgen Doser, and Torsten Lodderstedt. Model driven security: from uml models to access control infrastructures. *ACM Transactions on Software Engineering and Methodology*, 15(1):39–91, January 2006.

[5] CMS. Gdpr enforcement tracker. `https://www.enforcementtracker.com/`, 2024.

[6] Carolina Dania and Manuel Clavel. OCL2FOL+: coping with undefinedness. In *Proceedings of the MODELS 2013 OCL Workshop, Miami, USA, September 30, 2013*, volume 1092 of *CEUR Workshop Proceedings*, pages 53–62. CEUR-WS.org, 2013.

[7] Carolina Dania and Manuel Clavel. OCL2MSFOL: a mapping to many-sorted first-order logic for efficiently checking the satisfiability of OCL constraints. In Benoit Baudry and Benoît Combemale, editors, *Proceedings of the ACM/IEEE 19th International Conference on Model Driven Engineering Languages and Systems, Saint-Malo, France, October 2-7, 2016*, pages 65–75. ACM, 2016.

[8] Miguel Angel García de Dios, Carolina Dania, and Manuel Clavel. Formal reasoning about fine-grained access control policies. In *11th Asia-Pacific Conference on Conceptual Modelling (APCCM 2015), Sydney, Australia, January 2015*, volume 165 of *CRPIT*, pages 91–100. Australian Computer Society, 2015.

[9] Leonardo De Moura and Nikolaj Bjørner. Z3: an efficient smt solver. In *Proceedings of the Theory and Practice of Software, 14th International Conference on Tools and Algorithms for the Construction and Analysis of Systems*, TACAS'08/ETAPS'08, page 337–340, Berlin, Heidelberg, 2008. Springer-Verlag.

[10] European Parliament and Council. Regulation (EU) 2016/679, 2016. `https://eur-lex.europa.eu/eli/reg/2016/679/oj`.

[11] Srdan Krstic, Hoang Nguyen, and David A. Basin. Model-driven privacy. *Proc. Priv. Enhancing Technol.*, 2024(1):314–329, 2024.

[12] Object Constraint Language specification Version 2.4. Technical report, Object Management Group, February 2014. `https://www.omg.org/spec/OCL/`.

[13] Open Worldwide Application Security Project. OWASP Top 10. `https://owasp.org/Top10/2025/`, 2025.

[14] Ravi S Sandhu and Pierangela Samarati. Access control: principle and practice. *IEEE communications magazine*, 32(9):40–48, 1994.